
FedRAMP

Plain-Language Program and Assessment Guide

Consolidated Rules for 2026, FedRAMP 20x, and Rev5

What every requirement means, why it exists, how to audit it, what evidence to collect, how to document it, and how to report it.

Coverage

The 2026 program: Certification, Classes A–D, and the two paths.
FedRAMP 20x mechanics and all ten Key Security Indicator themes.
Ongoing Certification, including what replaced POA&Ms.
Agency responsibilities, and the Rev5 legacy path with its sunset.

Before You Use This Document

This is a companion guide, not a copy of the standard.

FedRAMP program materials are United States Government works in the public domain, so unlike the ISO guides in this series there is no copyright constraint on the underlying material. This guide still describes each rule in original plain language rather than reproducing program text, because the point is to make the rules usable rather than to restate them.

This guide describes a program that changed three weeks before it was written, and that intends to keep changing. The Consolidated Rules for 2026 took effect on 4 July 2026 and become enforceable on 1 January 2027. FedRAMP has stated that CR26 is the first milestone of a rule set it will update annually rather than a one-time change, and that requirements will continue to evolve. Several elements described here were still moving as this was written: the Key Security Indicator set has expanded across program phases and continues to refine, and rule changes have been progressing through public comment.

Check fedramp.gov before relying on any specific figure, date, or indicator count in this guide. Read the program's own rules for anything consequential. This guide is not legal advice, and where it and the program's published rules differ, the rules govern.

What this guide does

It takes each obligation in the Regulation and answers six questions about it, in the same order every time:

1. **What the obligation requires.** The requirement in ordinary language, with no assumed background.
2. **Why it exists.** The failure it is there to prevent. Auditors who understand intent write better findings than auditors who only know the wording.
3. **How to audit it.** Specific test steps, in the order you would actually perform them.
4. **Evidence to collect.** Named artifacts. Not “documentation” but the actual thing to request.
5. **How to document it.** What belongs in the workpaper so a reviewer can follow your reasoning without re-performing your work.
6. **Executive summary treatment.** Suggested language if the item fails or rates high risk, written for an audience that does not read control numbers.

On vocabulary

Technical terms are defined the first time they appear, shown like [this](#), and collected in the glossary. If you hit a term that is not defined, that is a defect in this document; note it and it will be fixed in the next revision.

Navigating this document

Each part opens with a quick-reference table. Every reference number and title in those tables is a live link to the full entry, so the tables work as a jump menu rather than just a contents list. Entries also appear in the PDF bookmark panel, and the index at the back links back into the text.

Link colour carries meaning. Here it marks one thing only: whether the material *changed under CR26*.

Orange, marked CR26

Changed materially under the Consolidated Rules for 2026, or belongs to the 20x path, which is new in its entirety. This is where prior FedRAMP experience actively misleads.

Blue

Carried forward substantially unchanged, or stable program structure.

The rule is chosen for this moment rather than for all time. Thirty-one of the forty entries here are orange, which is itself the headline: anyone approaching FedRAMP with experience from before July 2026 carries a mental model that is wrong in specific, identifiable places. Terminology moved, artefacts were renamed, and some obligations were removed outright. The orange entries are where to check assumptions first.

Blue does not mean unimportant, and here it means close to the opposite. The agency authorization to operate obligation is blue because it never changed. It remains the single most consequential point in this guide, and the persistent belief that a FedRAMP authorization was a blanket government-wide risk acceptance is the confusion the entire terminology change was made to dispel.

This is a transitional classification. Once CR26 is established practice it will stop being the most useful cut, and re-scoping to something like automated-validation versus documented-assertion would serve better.

The marker letters are printed as well as coloured, so the distinction survives greyscale printing and does not depend on colour vision. Whether a rule changed under CR26 is a matter of program record rather than a judgment of this guide, though the materiality threshold is mine; the classification is held in a single file in the source and can be re-scoped without touching any content.

One entry, one page

Every clause and control begins at the top of a fresh page and is complete before the next one starts. This wastes some paper and makes the document longer than it needs to be. It also means you can print a single control and hand it to the person who owns it, which is what these documents actually get used for.

How this guide is organized

The first chapter covers the 2026 program: what Certification is and is not, the Class A–D structure, the two paths, the roles, and the adoption timeline. The next two cover FedRAMP 20x, first its certification mechanics and then all ten Key Security Indicator themes. A chapter on Ongoing Certification follows, covering what a provider must do to keep a Certification once granted.

The final two chapters are written from the two sides. Agency Responsibilities covers what an agency must do regardless of any provider's certification status. FedRAMP Rev5 covers the legacy path, what CR26 changed about it, and how to plan the exit before it closes.

Entries address both points of view. Assessment steps are marked *provider side* or *agency side* where the work differs, and *both* where it does not.

Five things that catch people out

Certification is not an ATO, and never was. A certified service still requires the agency's own authorization to operate under Circular A-130. The belief that a FedRAMP authorization was a blanket government-wide risk acceptance was widespread enough that the program renamed the thing to stop it. If an agency has certified services in production with no separate ATO, that is the finding, and it belongs to the agency rather than the provider.

There is no Moderate any more. Low, Moderate, and High were replaced by Certification Classes A through D, and the mapping is deliberately loose: FedRAMP states there is no direct correlation, because providers tailor baselines and agencies incorporate services of differing categorizations into one system. Alignment is expressed per security objective, not as an overall level. An agency that adopts a provider's class as its own impact level has skipped the FIPS 199 categorization it is required to perform.

POA&Ms are gone. Eliminated outright, replaced by a list of Accepted Weaknesses, on the program's own reasoning that POA&Ms were mostly used to accept weaknesses for extended periods anyway. The substantive difference is honesty: a POA&M implied intent to remediate, an Accepted Weakness states the provider is living with it. For agency reviewers this list is the most informative artefact in the package, and the agency must decide separately whether it can live with the same things.

The significant change gate is gone too. Providers no longer request government permission to change their commercial product. That removed a real external control, and assurance that a service remains as assessed now rests entirely on provider change discipline and continuous validation. Ask what would tell an agency that a service it depends on had materially changed.

Automation coverage is the tell. For any 20x package, report the proportion of indicators validated automatically against the running system versus asserted in writing. That single figure distinguishes a provider that adopted the model from one that rewrote Rev5 narratives under new headings, and it is far more informative than the count of indicators marked true.

Three definitions you need before anything else

Certification vs authorization

FedRAMP grants a *Certification*: a reusable body of security information about a service. An agency grants an *authorization to operate*: a risk decision about using that service in its own system. The program supplies the first to make the second cheaper. It does not supply the second.

Certification Class

A through D, ascending in assurance, commitment, and cost. Class A suits an existing commercial product with a mature security programme and a SOC 2 Type II, and is the recommended entry point. Classes C and D are for providers with an established federal customer base. The class describes what the provider supplies, not how the agency must categorize its own system.

Key Security Indicator

A measurable security capability replacing control-by-control narrative under 20x. The model inverts the question: instead of *describe how you enforce this*, the indicator asks *produce evidence it is working right now*. That shifts the burden from writing to instrumenting, which is why the transition is harder than the reduced document count suggests.

How to read the executive summary sections

Every entry ends with suggested reporting language. It is deliberately written to avoid three habits that get security findings ignored: control numbers in the first sentence, adjectives about maturity, and recommendations that amount to “do it better.” Each one names a specific consequence and, where possible, attaches a number. Adapt the wording; keep the structure.

Contents

Before You Use This Document	ii
1 The 2026 Program	1
Certification FedRAMP Certification: what it is and what it is not	2
Classes A-D Certification Classes A, B, C, and D	3
Class alignment How classes align with agency use cases	4
Paths Choosing a path: FedRAMP 20x or FedRAMP Rev5	5
Roles Roles: FedRAMP, agencies, providers, assessors, advisors	6
Marketplace The FedRAMP Marketplace and listing	7
CR26 timeline The CR26 adoption timeline	8
2 FedRAMP 20x: Certification Mechanics	9
20x listing Marketplace listing under 20x	10
20x certification Obtaining 20x Certification	11
20x boundary The 20x FedRAMP boundary and Minimum Assessment Scope	12
20x assurance Assurance and the independent assessor	13
20x package Package materials: Certification Package Overview and Security Decision Record	14
20x automation Automated validation and machine-readable evidence	15
3 Key Security Indicators	16
KSI-CNA Cloud Native Architecture	17
KSI-SVC Service Configuration	18
KSI-IAM Identity and Access Management	19
KSI-MLA Monitoring, Logging, and Auditing	20
KSI-CMT Change Management	21
KSI-PIY Policy and Inventory	22
KSI-TPR Third-Party Information Resources	23
KSI-CED Cybersecurity Education	24
KSI-RPL Recovery Planning	25
KSI-INR Incident Reporting	26
4 Ongoing Certification	27
Ongoing Certification Ongoing Certification: what replaced continuous monitoring	28
VDR Vulnerability Detection and Response	29
Accepted Weaknesses Accepted Weaknesses: the replacement for POA&Ms	30
Change Change management and the end of significant change requests	31
Retention Retaining and losing Certification	32
5 Agency Responsibilities	33
Agency ATO The agency authorization to operate remains separate	34
Reuse Reuse and the presumption of adequacy	35

Agency categorization	Agency categorization under FIPS 199 and 200	36
Collaborative ConMon	Collaborative Continuous Monitoring	37
Package review	Reviewing a Certification Package	38
6	FedRAMP Rev5: The Legacy Path	39
Rev5 status	Rev5 status and the transition timeline	40
Rev5 controls	Rev5 control guidance and the SP 800-53 baseline	41
Rev5 package	Rev5 package materials under CR26	42
Rev5 ongoing	Rev5 Ongoing Certification changes	43
Rev5 boundary	The Rev5 FedRAMP boundary	44
Rev5 assurance	Rev5 assurance and assessment	45
Rev5 transition	Planning the transition to 20x	46
	Glossary	47
	Index of Terms and Concepts	50

CHAPTER 1

The 2026 Program

Seven entries on the program as it now stands. What a FedRAMP Certification is and is not, the Class A to D structure that replaced Low, Moderate, and High, the two certification paths, the roles, the Marketplace, and the adoption timeline.

Read the first entry before anything else. FedRAMP Certification does not replace an agency authorization to operate, and it never did. The belief that it constituted a blanket government-wide risk acceptance was widespread enough that the program renamed the thing to stop it. An agency using a certified service still owes its own risk determination under Circular A-130.

The rest of this chapter exists because the vocabulary moved. If you carry experience from before July 2026, the terms you know have been renamed, some artefacts have been eliminated outright, and the impact levels you are looking for no longer exist.

Quick reference: the 2026 program

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [cyb](#) or [ai](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
Certification CR26	FedRAMP Certification: what it is and what it is not	Agency ATO documentation per certified service in use
Classes A-D CR26	Certification Classes A, B, C, and D	Certification class per service with rationale
Class alignment CR26	How classes align with agency use cases	Per-objective adequacy analysis for the intended use
Paths CR26	Choosing a path: FedRAMP 20x or FedRAMP Rev5	Path selection rationale
Roles	Roles: FedRAMP, agencies, providers, assessors, advisors	Assessor independence evidence
Marketplace CR26	The FedRAMP Marketplace and listing	Marketplace listing record
CR26 timeline CR26	The CR26 adoption timeline	CR26 adoption plan with rule set mapping

Certification FedRAMP Certification: what it is and what it is not

WHAT THE RULE REQUIRES

FedRAMP Certification is the label the program grants to a cloud service offering that has met FedRAMP's requirements. Under the Consolidated Rules for 2026 the term replaced FedRAMP authorization, because the statute defines a FedRAMP authorization as a certification that a product or service has completed a FedRAMP authorization process, and the old wording invited confusion with an agency authorization to operate. A Certification is a reusable body of security information about a service. It is not a blanket risk acceptance across the federal government, and it does not by itself permit an agency to use the service.

WHY IT EXISTS

The single most persistent misunderstanding in FedRAMP has been the belief that a certified service is cleared for government-wide use. It is not. An agency must still make its own authorization to operate decision under OMB Circular A-130, and Certification exists to make that decision cheaper and faster by supplying reusable, comparable security information. Getting this wrong produces two failures: providers who believe certification wins them the market outright, and agencies who deploy a certified service without performing their own risk determination.

HOW TO ASSESS IT

1. Agency side: confirm an agency ATO exists for each certified service in use, separate from the provider's Certification.
2. Agency side: check the ATO reflects the agency's own use case rather than restating the provider's certification status.
3. Provider side: verify marketing and contractual language describes Certification accurately and does not imply government-wide approval.
4. Both: confirm the distinction between Certification and agency ATO is understood by the people making deployment decisions.

EVIDENCE TO COLLECT

- Agency ATO documentation per certified service in use
- Certification status evidence from the Marketplace
- Provider representations in contracts and marketing

HOW TO DOCUMENT IT

Record whether an agency ATO exists distinct from the provider's Certification for each service in scope. A deployment resting on Certification alone has had no agency risk decision made about it, which is the finding regardless of how good the provider's security is.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of certified cloud services are in production without a separate agency authorization to operate, so the agency has accepted no documented risk for services its mission depends on.

Classes A-D Certification Classes A, B, C, and D

WHAT THE RULE REQUIRES

CR26 replaced the Low, Moderate, and High impact levels with four Certification Classes, A through D. Each class provides progressively more assurance, commitment, and alignment with diverse agency needs, and requires more preparation, federal process maturity, automation, verification, and cost. Class A is designed for existing commercial products that already hold a SOC 2 Type II certification and a mature security program, and is the recommended entry point. Classes C and D are intended for providers with an active federal customer base who have already invested in a federal compliance program.

WHY IT EXISTS

The class system exists because a commercial cloud service is usually a component within a federal information system, not a federal information system itself. Agencies remain obliged by FIPS 199 and FIPS 200 to categorize their own systems and select baselines, and the class tells them how much assurance the service supplies toward that determination rather than substituting for it. This is why classes are designed to be undertaken progressively, scaling investment with actual agency demand.

HOW TO ASSESS IT

1. Provider side: verify the class chosen matches actual agency customer requirements rather than aspiration, since higher classes carry substantial ongoing cost.
2. Agency side: check the class of each service supplies adequate information for the security objectives of the system it sits within.
3. Both: confirm documentation and marketing use class terminology rather than legacy impact-level labels.
4. Agency side: verify the agency performed its own FIPS 199 categorization rather than inheriting the provider's class as its impact level.

EVIDENCE TO COLLECT

- Certification class per service with rationale
- Agency FIPS 199 categorization for the containing system
- Marketplace listing showing current class

HOW TO DOCUMENT IT

Record whether the agency treats the provider's class as its own impact level, which is a category error: the class describes assurance supplied, not the categorization of the agency system the service sits inside.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the agency has adopted the provider's Certification Class as the impact level of its own system rather than performing the FIPS 199 categorization it is required to perform, so the control baseline for the containing system was never properly determined.

Class alignment How classes align with agency use cases

WHAT THE RULE REQUIRES

FedRAMP states that classes loosely align with the baseline security expectations for FIPS 199 impact levels, but there is deliberately no direct correlation. Class A supplies adequate information for most non-sensitive use cases and some Low, Moderate, or High security objectives. Class B covers most Low objectives and some Moderate or High. Class C covers most Low and Moderate objectives and some High. Class D covers most use cases regardless of security objective, excluding classified systems. The absence of a direct mapping is because providers may tailor controls within a baseline, and agencies may include services of differing categorizations within one system through tailoring, compensating controls, or information flow control.

WHY IT EXISTS

Anyone carrying forward the old mental model will look for a Moderate equivalent and there is not one. The alignment is expressed per security objective rather than as an overall level, which is a meaningful change: a service may supply adequate assurance for the confidentiality objective of a Moderate system while not doing so for availability. That granularity is the point, and it is lost if the class is read as a simple substitute for an impact level.

HOW TO ASSESS IT

1. Agency side: assess class adequacy per security objective rather than overall, since the alignment is expressed that way.
2. Agency side: where a service supplies inadequate assurance for one objective, check for compensating controls or information flow controls.
3. Provider side: verify claims about which agency use cases the class supports are accurate and not overstated.
4. Both: look for services being placed in systems whose objectives the class does not adequately support.

EVIDENCE TO COLLECT

- Per-objective adequacy analysis for the intended use
- Compensating control or flow control evidence
- System categorization for comparison

HOW TO DOCUMENT IT

Assess adequacy per security objective and record any objective where the class does not supply adequate assurance, together with what compensates for it. A blanket statement that the class is sufficient has not done this analysis.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a service was accepted into a system on the basis of its Certification Class without per-objective analysis, and the class does not supply adequate assurance for the availability objective of the containing system.

Paths Choosing a path: FedRAMP 20x or FedRAMP Rev5

WHAT THE RULE REQUIRES

Two certification paths exist. FedRAMP 20x is the modernized path: it uses Key Security Indicators rather than control-by-control narratives, does not require agency sponsorship, and relies heavily on automated validation against the running service. FedRAMP Rev5 is the legacy path: it uses the NIST SP 800-53 Rev 5 control baselines, requires an agency sponsor, and depends on manual review of extensive documentation. FedRAMP will stop accepting new Rev5 Certifications on June 11, 2027, and existing Rev5 Certifications remain active until at least December 31, 2028 unless FedRAMP is otherwise directed.

WHY IT EXISTS

The absence of a sponsorship requirement in 20x is the structural change that matters most commercially: under Rev5 a provider could not obtain certification without persuading an agency to commit staff time and review cycles, which was the primary bottleneck. Removing it changes who can enter the market. For anyone planning work, the sunset dates are the operative facts: Rev5 is a closing path, and a programme scoped only against it is planning around an asset with a known end date.

HOW TO ASSESS IT

1. Provider side: confirm the path chosen accounts for the Rev5 sunset dates and that a transition plan exists.
2. Provider side: where an agency sponsorship is stalled under Rev5, assess whether 20x removes the blocker.
3. Agency side: verify reviewers are equipped to evaluate 20x packages, which look materially different from Rev5 packages.
4. Both: check that timelines and budgets reflect the June 2027 and December 2028 dates.

EVIDENCE TO COLLECT

- Path selection rationale
- Transition plan from Rev5 to 20x where applicable
- Agency reviewer capability for 20x packages

HOW TO DOCUMENT IT

Record whether a Rev5 provider has a transition plan with dates, since certification lapses at the end of the window and re-entering through 20x is not instantaneous.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization holds a Rev5 Certification with no transition plan to FedRAMP 20x, so it is scheduled to lose certification at the close of the legacy window with no route prepared to retain it.

Roles Roles: FedRAMP, agencies, providers, assessors, advisors**WHAT THE RULE REQUIRES**

CR26 organizes rules by role. FedRAMP itself sets the rules, maintains the Marketplace, and grants Certification. Agencies make their own authorization to operate decisions, perform continuous monitoring under Circular A-130, and may collaborate with providers on Collaborative Continuous Monitoring. Cloud service providers implement the rules, produce package materials, and maintain Ongoing Certification. Independent assessors validate provider claims and supply the assurance FedRAMP and agencies rely on. Advisors assist providers in preparing, without themselves granting anything.

WHY IT EXISTS

Role clarity matters more under CR26 than before, because the program devolved a great deal of judgment to providers. FedRAMP removed most of its prescriptive organizational parameters and expects providers to define their own, which means the independent assessor's validation carries more weight than it did when FedRAMP specified the answers. Confusing an advisor with an assessor is a live risk: advisors help prepare, assessors validate, and the two cannot be the same party for the same service.

HOW TO ASSESS IT

1. Provider side: verify the independent assessor is genuinely independent of the advisory work and of implementation.
2. Agency side: confirm the agency understands what the assessor validated and what remains its own risk decision.
3. Both: check that advisors are not presented as conferring any FedRAMP status.
4. Provider side: confirm internal ownership of each role-based obligation under CR26.

EVIDENCE TO COLLECT

- Assessor independence evidence
- Advisor engagement scope
- Role assignment against CR26 rule sets

HOW TO DOCUMENT IT

Record whether the same party advised on preparation and then assessed, since that compromises the independence the whole assurance model rests on.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the party that prepared the certification materials also performed the independent assessment, so the validation supporting the Certification lacks independence.

Marketplace The FedRAMP Marketplace and listing

WHAT THE RULE REQUIRES

The Marketplace is the public register of cloud service offerings and their FedRAMP status. Under CR26 it was updated for the new class structure, and it distinguishes the 20x and Rev5 paths through filters rather than through separate status labels. FedRAMP considered and rejected a separate validated designation for the two paths, on the basis that a second label would add procurement confusion. Listing rules differ between the 20x and Rev5 paths and are set out separately in the respective rule sets.

WHY IT EXISTS

The Marketplace is where agencies actually look, so listing accuracy has direct commercial and procurement consequence. The decision not to distinguish paths by label means an agency reviewer must use filters to know whether a listing came through 20x or Rev5, and the underlying package materials differ substantially between them. A reviewer who does not check will not know what kind of evidence to expect.

HOW TO ASSESS IT

1. Provider side: verify the Marketplace listing is current and reflects the correct class and path.
2. Provider side: check that materials and marketing no longer hard-code FedRAMP Authorized or legacy impact-level labels.
3. Agency side: confirm reviewers check which path a listing came through before assessing the package.
4. Both: verify status claims made in procurement match the Marketplace record.

EVIDENCE TO COLLECT

- Marketplace listing record
- Marketing and contractual status claims
- Procurement documentation referencing FedRAMP status

HOW TO DOCUMENT IT

Record any material still describing the service as FedRAMP Authorized or by a legacy impact level, since the terminology changed and stale claims signal a provider that has not adopted CR26.

EXECUTIVE SUMMARY TREATMENT

Suggested language: procurement documentation and vendor marketing continue to describe services using retired FedRAMP Authorized and impact-level terminology, so the agency cannot confirm from those materials what assurance a service actually supplies.

CR26 timeline The CR26 adoption timeline

WHAT THE RULE REQUIRES

The Consolidated Rules for 2026 took effect on July 4, 2026 and are immediately applicable to all cloud service offerings seeking to obtain or maintain a FedRAMP Certification. An extended early adoption phase applies to Rev5, with only a few rule sets mandatory before January 1, 2027. After January 1, 2027, enforcement begins. FedRAMP has stated that providers that do not adjust to the updated rules will lose their Certification, and that CR26 is the first milestone of an annually updated rule set rather than a one-time change.

WHY IT EXISTS

The annual update model is the part with lasting consequence. CR26 is not a migration to a new stable state; the program has committed to evolving its rules every year to incorporate emerging threats, technologies, and methodologies. A compliance approach built on hand-maintained documents and a multi-year refresh cycle cannot keep pace with that, which is why the program pairs it with a push toward automation and machine-readable materials.

HOW TO ASSESS IT

1. Provider side: verify a plan exists to meet the January 1, 2027 enforcement date, with the rule sets mapped.
2. Provider side: assess whether the organization's GRC capability can absorb an annual rule update.
3. Agency side: check that agency processes and reviewer training are being updated for CR26.
4. Both: identify any process still dependent on retired artefacts such as POA&Ms or Word-based templates.

EVIDENCE TO COLLECT

- CR26 adoption plan with rule set mapping
- GRC tooling capability assessment
- Processes dependent on retired artefacts

HOW TO DOCUMENT IT

Record whether the organization treats CR26 as a one-time migration or as the first of recurring annual updates, since the second requires durable automation rather than a project.

EXECUTIVE SUMMARY TREATMENT

Suggested language: CR26 adoption is being run as a one-time documentation project with no investment in the automation the program's annual update model requires, so the organization will face the same effort again each year.

CHAPTER 2

FedRAMP 20x: Certification Mechanics

Six entries on how a 20x Certification is actually obtained and what it covers. Orange throughout, because the entire path is new.

The defining change is that 20x inverts the assessment question. Under Rev5 an assessor asked a provider to describe how it implemented a control. Under 20x the indicator asks the provider to produce evidence that the capability is working in the running system now. That moves the burden from writing to instrumenting, and it is why providers whose compliance function is documentation-led find the transition harder than the reduced document count suggests.

Two tests carry most of the weight. First, report the proportion of indicators validated automatically against those asserted in writing: that single figure shows whether a provider adopted the 20x model or recreated Rev5 narratives under new headings. Second, trace federal information through the actual delivery path and compare against the declared boundary. Management and support planes are the usual finding, because they are easy to omit and hold privileged access.

Quick reference: 20x Mechanics

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [cyb](#) or [ai](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
20x listing CR26	Marketplace listing under 20x	Marketplace listing record with class and status
20x certifica- tion CR26	Obtaining 20x Certification	KSI coverage showing every indicator addressed
20x boundary CR26	The 20x FedRAMP boundary and Minimum Assessment Scope	Boundary definition and data flow evidence
20x assurance CR26	Assurance and the independent assessor	Assessor attestation with scope
20x package CR26	Package materials: Certification Package Overview and Security Decision Record	Certification Package Overview
20x automa- tion CR26	Automated validation and machine-readable evidence	Automated validation pipeline and output

20x listing Marketplace listing under 20x

WHAT THE RULE REQUIRES

A provider seeking 20x Certification lists its cloud service offering on the FedRAMP Marketplace under the rules set out in the 20x rule set. Listing occurs before Certification is granted and signals intent and progress, and no agency sponsor is required to list or to proceed. The Marketplace record carries the Certification Class and, through filters, the path by which the listing is proceeding.

WHY IT EXISTS

Under Rev5 the inability to list or progress without a sponsor was the primary structural barrier to entry, and removing it is the change that most directly serves the program's goal of rapidly increasing the size of the Marketplace. For agencies, it means listings will appear from providers with no existing federal relationship, which changes what a listing implies about a provider's federal maturity.

HOW TO ASSESS IT

1. Provider side: confirm listing details are accurate and current, including class and offering description.
2. Provider side: verify the offering as listed matches the offering as assessed and boundaries described.
3. Agency side: check what stage a listing represents, since listing is not Certification.
4. Agency side: assess federal process maturity separately, since it is no longer implied by the presence of a sponsor.

EVIDENCE TO COLLECT

- Marketplace listing record with class and status
- Offering description compared to assessed scope

HOW TO DOCUMENT IT

Record whether the listed offering matches what was actually assessed, since a listing describing a broader service than the assessed boundary misrepresents what the Certification covers.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the Marketplace listing describes a broader service than the boundary that was assessed, so agencies relying on the listing may deploy components that carry no FedRAMP assurance.

20x certification Obtaining 20x Certification

WHAT THE RULE REQUIRES

A provider obtains 20x Certification by applying all Key Security Indicators to everything within the FedRAMP Minimum Assessment Scope, validating them, having those validations reviewed by an independent assessor, and submitting the resulting package materials. FedRAMP's rules require that providers apply all KSIs to all aspects of the offering within scope. Validation is expected to be automated wherever the capability can be derived from technical configuration, and evidence is expected to be available in both human-readable and machine-readable form.

WHY IT EXISTS

The 20x model inverts the assessment question. Under Rev5 an assessor asked a provider to describe how it implemented a control; under 20x the KSI asks the provider to produce evidence that the capability is working in the running system now. That shift moves the burden from writing to instrumenting, and providers whose compliance function is documentation-led rather than engineering-led find the transition harder than the reduced document count suggests.

HOW TO ASSESS IT

1. Provider side: verify every KSI is addressed and that none is silently omitted as inapplicable.
2. Provider side: assess what proportion of validation is automated against what is asserted, since automation coverage expectations are substantial.
3. Agency side: check that evidence is genuinely derived from the running system rather than restated from documentation.
4. Both: confirm machine-readable evidence exists alongside the human-readable form.

EVIDENCE TO COLLECT

- KSI coverage showing every indicator addressed
- Automated validation output with generation timestamps
- Machine-readable evidence artefacts

HOW TO DOCUMENT IT

Report the proportion of KSIs validated automatically against those asserted through documentation, since this single figure indicates whether the provider has actually adopted the 20x model or recreated Rev5 narratives under new headings.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated proportion of Key Security Indicators are supported by written assertion rather than automated validation against the running service, so the certification rests on the documentation-led model that 20x was designed to replace.

20x boundary The 20x FedRAMP boundary and Minimum Assessment Scope

WHAT THE RULE REQUIRES

The 20x rules define the FedRAMP boundary and the Minimum Assessment Scope: the set of information resources to which all Key Security Indicators must be applied. Scope encompasses the components that handle federal information or that are likely to affect the confidentiality, integrity, or availability of federal information, including third-party information resources within that description. The boundary definition determines what is assessed, what is certified, and what an agency may rely upon.

WHY IT EXISTS

Boundary is where certification scope is either honest or convenient. A boundary drawn narrowly excludes components from assessment while leaving them in the delivery path, so the service an agency actually consumes is broader than the service that was certified. Because the KSIs must be applied to everything within scope, an artificially narrow boundary is the most efficient way to reduce assessment burden and the most consequential misrepresentation available.

HOW TO ASSESS IT

1. Provider side: test the boundary against actual data flows, identifying components handling federal information that sit outside it.
2. Provider side: verify third-party information resources within the delivery path are accounted for.
3. Agency side: compare the certified boundary against the service as actually consumed.
4. Both: examine management, support, and monitoring planes, which are commonly excluded and commonly have access.

EVIDENCE TO COLLECT

- Boundary definition and data flow evidence
- Component inventory against boundary
- Third-party resource identification
- Management and support plane access analysis

HOW TO DOCUMENT IT

Trace federal information through the actual delivery path and record any component that handles it while sitting outside the boundary. Management and support planes are the usual finding, because they are easy to overlook and hold privileged access.

EXECUTIVE SUMMARY TREATMENT

Suggested language: components with privileged access to federal information, including the management and support planes, sit outside the assessed boundary, so the Certification does not cover parts of the service that could compromise the data it protects.

20x assurance Assurance and the independent assessor

WHAT THE RULE REQUIRES

The 20x rules set out how assurance is established: an independent assessor reviews the provider's KSI validations and the evidence supporting them, and attests to what has been validated. Because FedRAMP removed most of its prescriptive organizational parameters under CR26 and expects providers to define their own, the assessor's judgment about whether a provider's chosen approach actually satisfies the indicator carries more weight than under the legacy model.

WHY IT EXISTS

This is the structural consequence of devolving judgment to providers. Under legacy FedRAMP, a parameter such as a review frequency was specified, so assessment was largely a matter of checking conformance. Under CR26 the provider sets many of those values and competes on quality, which means the assessor is now judging adequacy rather than conformance. An assessment that only confirms the provider did what it said it would do is no longer sufficient.

HOW TO ASSESS IT

1. Provider side: verify assessor independence from both implementation and advisory work.
2. Agency side: examine whether the assessor evaluated adequacy of provider-defined parameters or only conformance to them.
3. Both: check the assessor's scope covers the full Minimum Assessment Scope.
4. Agency side: identify which KSIs the assessor qualified or noted, since these are where risk concentrates.

EVIDENCE TO COLLECT

- Assessor attestation with scope
- Independence evidence
- Provider-defined parameters and the assessor's evaluation of them

HOW TO DOCUMENT IT

Record whether the assessor evaluated the adequacy of provider-defined parameters, since under CR26 confirming conformance to a provider's own chosen values establishes very little.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the independent assessment confirmed conformance to provider-defined parameters without evaluating whether those parameters are adequate, so the assurance supplied does not address whether the security outcomes are sufficient.

20x package Package materials: Certification Package Overview and Security Decision Record**WHAT THE RULE REQUIRES**

CR26 replaced the System Security Plan and its appendices with the Certification Package Overview and the Security Decision Record. The reasoning is that Certification is based on the actual outcomes of decisions a provider made, not on plans: the provider does not supply a security plan for an agency to implement, it supplies a record of security decisions for the agency to assess. CR26 also moves package materials away from Word and Excel templates toward simplified JSON documents and, in some cases, optional OSCAL.

WHY IT EXISTS

The renaming reflects a genuine conceptual change rather than a relabel. A plan describes intent; a decision record describes what was chosen and why, which is what an agency actually needs to assess risk. The format shift matters operationally: providers are expected to populate materials from real-world data using automation rather than maintaining hand-crafted documents, and organizations whose compliance function is built around document authorship will struggle.

HOW TO ASSESS IT

1. Provider side: verify materials are in the required formats and populated from real data rather than transcribed.
2. Agency side: assess whether the Security Decision Record explains decisions and rationale rather than restating requirements.
3. Both: check materials are current, since automated population should mean they reflect the present state.
4. Provider side: identify any material still maintained as a hand-crafted document.

EVIDENCE TO COLLECT

- Certification Package Overview
- Security Decision Record
- Format and generation evidence

HOW TO DOCUMENT IT

Record whether package materials are generated from system data or hand-maintained, since hand-maintained materials drift from reality between updates and CR26 is explicitly designed to end that practice.

EXECUTIVE SUMMARY TREATMENT

Suggested language: package materials are maintained as hand-crafted documents rather than generated from system data, so they describe the service as it was last documented rather than as it currently operates.

20x automation Automated validation and machine-readable evidence

WHAT THE RULE REQUIRES

The 20x model depends on validation that can be derived automatically from technical configuration and produced continuously rather than at assessment time. FedRAMP's stated expectation is that the majority of a security assessment can take place continuously through automated validation for simple cloud-native services once the control-by-control narrative requirement is removed. Evidence is expected in both human-readable and machine-readable form, and the program's statutory mandate includes establishing a means for the automation of security assessments and reviews.

WHY IT EXISTS

Automation is the mechanism that makes the rest of 20x work: continuous validation, faster agency review, and reuse across agencies all depend on evidence that can be produced and consumed by machine. It is also the highest bar in practice. Teams routinely underestimate what automated compliance evidence requires, because it means instrumenting the running system rather than describing it, and it exposes any gap between documented and actual configuration immediately.

HOW TO ASSESS IT

1. Provider side: verify validation output is generated from the running system with timestamps rather than compiled periodically by hand.
2. Provider side: test whether a validation would fail if the underlying configuration drifted.
3. Agency side: confirm machine-readable evidence can actually be consumed and is not merely a document in a structured wrapper.
4. Both: check the frequency of validation generation against the continuous expectation.

EVIDENCE TO COLLECT

- Automated validation pipeline and output
- Generation timestamps and frequency
- Machine-readable evidence samples
- Drift detection evidence

HOW TO DOCUMENT IT

Test whether a validation would actually fail on configuration drift, since a pipeline that reports success regardless of state is reporting rather than validating.

EXECUTIVE SUMMARY TREATMENT

Suggested language: automated validations report success without testing the underlying configuration, so they would not detect drift and provide no assurance beyond confirming the pipeline ran.

CHAPTER 3

Key Security Indicators

Ten indicator themes that replace control-by-control narrative under 20x. Each theme carries a set of validation requirements that must be met and reported as true, and FedRAMP requires providers to apply all indicators to everything within the Minimum Assessment Scope.

A caution on currency. The indicator set continues to evolve: it was first published for the Phase One pilot, expanded for Phase Two, and continues to refine under CR26. This chapter describes the published themes and their validation requirements, which are stable in structure, but check the current standard for the exact indicator set and count before relying on it.

Several requirements are stricter than common commercial practice and are worth identifying early. KSI-IAM requires phishing-resistant multi-factor authentication, which code-based methods do not satisfy, and just-in-time privilege rather than standing access. KSI-MLA requires tamper-resistant logging and authenticated vulnerability scanning, and unauthenticated scanning is the easiest way to produce favourable numbers that understate exposure. KSI-CNA requires genuinely immutable infrastructure, and in-place modification defeats the state guarantees the whole automated validation model depends on. KSI-PIY is unusual in requiring dedicated security staffing and budget proportionate to the service, which is an explicit resourcing obligation rather than a process one.

Quick reference: Key Security Indicators

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [CYB](#) or [AI](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
KSI-CNA CR26	Cloud Native Architecture	Traffic control configuration across resources
KSI-SVC CR26	Service Configuration	Encryption coverage by data category with FIPS-140 status
KSI-IAM CR26	Identity and Access Management	Authentication method inventory with phishing resistance status
KSI-MLA CR26	Monitoring, Logging, and Auditing	SIEM configuration and tamper resistance evidence
KSI-CMT CR26	Change Management	Deployment records for population reconciliation
KSI-PIY CR26	Policy and Inventory	Resource inventory reconciled to discovery
KSI-TPR CR26	Third-Party Information Resources	Third-party resource inventory with authorization status
KSI-CED CR26	Cybersecurity Education	Training completion against full population
KSI-RPL CR26	Recovery Planning	Defined RTO and RPO
KSI-INR CR26	Incident Reporting	Incident log with reporting timestamps

KSI-CNA Cloud Native Architecture

WHAT THE RULE REQUIRES

A secure cloud service offering uses cloud native architecture and design principles to enforce and enhance confidentiality, integrity, and availability. Validation requires configuring all information resources to limit inbound and outbound traffic, designing systems to minimize attack surface and lateral movement if compromised, using logical networking to enforce traffic flow controls, using immutable infrastructure with strictly defined functionality and privileges by default, having denial of service protection, designing for high availability and rapid recovery, and implementing cloud-native resources following the host provider's documented best practices.

WHY IT EXISTS

This indicator encodes the architectural assumptions the rest of the model depends on. Immutable infrastructure and minimized lateral movement are what make automated validation meaningful: a system rebuilt from version-controlled definitions has a knowable state, while one modified in place does not. A provider that has not adopted these principles will find every other KSI harder to validate automatically.

HOW TO ASSESS IT

1. Test traffic restriction on actual resources rather than reviewing the network design.
2. Assess lateral movement by examining what a compromised component could reach.
3. Verify infrastructure is genuinely immutable, checking whether in-place modification is possible and whether it occurs.
4. Agency side: consider whether the architecture supports the availability objective of the containing system.

EVIDENCE TO COLLECT

- Traffic control configuration across resources
- Network segmentation and flow control evidence
- Immutable deployment pipeline and drift records
- Denial of service protection and availability design

HOW TO DOCUMENT IT

Record whether infrastructure is modified in place despite an immutable design, since in-place changes defeat the state guarantees that make the automated validation model work.

EXECUTIVE SUMMARY TREATMENT

Suggested language: infrastructure described as immutable is routinely modified in place, so the running configuration diverges from its version-controlled definition and automated validation reflects the definition rather than reality.

KSI-SVC Service Configuration

WHAT THE RULE REQUIRES

A secure offering follows FedRAMP encryption policies, continuously verifies information resource integrity, and restricts access to third-party resources. Validation requires hardening and reviewing network and system configurations, encrypting or otherwise securing network traffic, encrypting all federal and sensitive information at rest, managing configuration centrally, enforcing system and information resource integrity through cryptographic means, using automated key management to manage, protect, and regularly rotate keys and certificates, and applying security patches through a consistent risk-informed approach.

WHY IT EXISTS

CR26 changed the encryption expectation materially. FIPS-140 encryption is now expected to protect sensitive data, and FedRAMP no longer assumes all federal customer data and metadata is sensitive; instead providers document their use of FIPS-140 encryption so agencies can determine how it aligns with their intended use. That shifts a determination from the program to the provider and then to the agency, which means an agency must actually read the documentation rather than assuming blanket coverage.

HOW TO ASSESS IT

1. Verify what is encrypted and with what, and compare against what the provider documents as sensitive.
2. Agency side: assess whether the provider's sensitivity determination matches the agency's own data classification.
3. Test key management automation, including rotation actually occurring rather than being configured.
4. Examine patch application timeliness against the provider's stated risk-informed approach.

EVIDENCE TO COLLECT

- Encryption coverage by data category with FIPS-140 status
- Provider sensitivity determination
- Key management and rotation evidence
- Patch timeliness records

HOW TO DOCUMENT IT

Record the provider's sensitivity determination against the agency's own classification, since CR26 no longer assumes all federal data is sensitive and a mismatch means agency data may be outside the encryption the provider applies.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the provider's determination of which data is sensitive excludes categories the agency classifies as sensitive, so agency data is stored without the FIPS-140 encryption the agency assumed applied to it.

KSI-IAM Identity and Access Management

WHAT THE RULE REQUIRES

A secure offering protects user data, controls access, and applies zero trust principles. Validation requires enforcing phishing-resistant multi-factor authentication for all user authentication, using secure passwordless methods where feasible and otherwise strong passwords with MFA, enforcing appropriately secure authentication for non-user accounts and services, using a least-privileged, role and attribute-based, just-in-time authorization model for all user and non-user accounts and services, applying zero trust design principles, and automatically disabling or securing privileged accounts in response to suspicious activity.

WHY IT EXISTS

The phishing-resistant qualifier is the demanding part: ordinary multi-factor authentication using one-time codes does not satisfy it, because those methods can be intercepted or relayed. The just-in-time element is equally strict, requiring that privilege be granted for a period rather than held standing. Both are higher bars than most commercial programmes clear, and both are directly testable.

HOW TO ASSESS IT

1. Test whether multi-factor methods in use are genuinely phishing-resistant rather than code-based.
2. Verify non-user and service account authentication, which is commonly weaker than user authentication.
3. Assess whether privilege is just-in-time or standing, by examining how long privileged access persists.
4. Test automatic response to suspicious privileged activity.

EVIDENCE TO COLLECT

- Authentication method inventory with phishing resistance status
- Service and non-user account authentication
- Privilege duration evidence
- Automated privileged account response configuration

HOW TO DOCUMENT IT

Record which multi-factor methods are actually in use and whether they meet the phishing-resistant standard, since code-based methods are widely deployed and do not satisfy this indicator.

EXECUTIVE SUMMARY TREATMENT

Suggested language: multi-factor authentication relies on one-time codes that are not phishing-resistant, and privileged access is held standing rather than granted just in time, so two explicit requirements of this indicator are unmet.

KSI-MLA Monitoring, Logging, and Auditing

WHAT THE RULE REQUIRES

A secure offering monitors, logs, and audits all important events, activity, and changes. Validation requires operating a SIEM or similar system for centralized, tamper-resistant logging of events, activities, and changes; regularly reviewing and auditing logs; rapidly detecting and remediating or mitigating vulnerabilities; performing authenticated vulnerability scanning; performing infrastructure as code and configuration evaluation and testing; and centrally tracking and prioritizing the mitigation or remediation of identified vulnerabilities.

WHY IT EXISTS

Two requirements here are stricter than common practice. Tamper-resistant is explicit, so a log store administrators can alter does not satisfy the indicator. Authenticated scanning is also explicit, and unauthenticated scanning materially understates vulnerability counts, which is why some providers prefer it. The infrastructure as code evaluation requirement extends scanning to the definitions themselves rather than only the deployed result.

HOW TO ASSESS IT

1. Verify logging is tamper-resistant, testing whether administrators can alter or delete records of their own activity.
2. Confirm vulnerability scanning is authenticated and covers the full scope.
3. Check infrastructure as code and configuration evaluation actually occurs.
4. Assess whether log review happens and produces findings, since collection without review detects nothing.

EVIDENCE TO COLLECT

- SIEM configuration and tamper resistance evidence
- Scan configuration showing authentication and coverage
- IaC evaluation results
- Log review records with findings

HOW TO DOCUMENT IT

Verify scanning is authenticated and record coverage, since unauthenticated scanning produces favourable numbers that do not reflect actual exposure and is the easiest way to appear compliant.

EXECUTIVE SUMMARY TREATMENT

Suggested language: vulnerability scanning is unauthenticated and log storage can be altered by the administrators whose activity it records, so neither the vulnerability position nor the audit trail can be relied upon.

KSI-CMT Change Management**WHAT THE RULE REQUIRES**

A secure provider ensures all system changes are properly documented and configuration baselines updated accordingly. Validation requires logging and monitoring system modifications, executing changes through redeployment of version-controlled immutable resources rather than direct modification wherever possible, implementing automated testing and validation of changes prior to deployment, having a documented change management procedure, and evaluating the risk and potential impact of any change.

WHY IT EXISTS

CR26 removed the legacy significant change request process, under which providers had to ask the government for permission to change their commercial product, and which FedRAMP acknowledged had slowed innovation substantially. The replacement puts the obligation on the provider's own change discipline. That is a meaningful transfer of trust, and it makes this indicator the one that carries the weight the old approval gate used to.

HOW TO ASSESS IT

1. Establish the change population from deployment records and reconcile against change management records.
2. Verify changes are executed by redeployment rather than direct modification, and quantify the exceptions.
3. Check automated pre-deployment testing exists and would actually block a failing change.
4. Confirm risk and impact evaluation occurs before deployment rather than after.

EVIDENCE TO COLLECT

- Deployment records for population reconciliation
- Change management records with risk evaluation
- Automated test gate configuration and blocked-change evidence

HOW TO DOCUMENT IT

Establish the change population from deployment logs rather than the change tool, and record changes made outside the process, since the removal of the government approval gate makes provider change discipline the only remaining control.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated proportion of production changes were made by direct modification outside the version-controlled deployment process, so the change discipline that replaced the former government approval gate is not operating.

KSI-PIY Policy and Inventory**WHAT THE RULE REQUIRES**

A secure offering has intentional, organized, universal guidance for how every information resource, including personnel, is secured. Validation requires an up-to-date information resource inventory or code defining all deployed assets, software, and services; policies outlining the security objectives of all information resources; a vulnerability disclosure program; security considerations built into the software development lifecycle aligned with CISA Secure By Design principles; documented methods for evaluating resource implementations; dedicated staff and budget for security with executive support commensurate with the size, complexity, scope, and risk of the offering; and documented risk management decisions for software supply chain security.

WHY IT EXISTS

The dedicated staff and budget requirement is unusual and worth noting: it is an explicit resourcing obligation, not merely a process one, and it is proportionate to the service. A provider claiming a mature security posture with no dedicated budget or executive sponsorship fails this indicator regardless of its technical controls. The vulnerability disclosure program requirement is similarly concrete and externally verifiable.

HOW TO ASSESS IT

1. Reconcile the resource inventory against independent discovery, since inventory completeness underpins every other indicator.
2. Verify a vulnerability disclosure program exists and is reachable externally.
3. Assess whether dedicated security staffing and budget exist and are proportionate to the service.
4. Check supply chain risk decisions are documented rather than implicit.

EVIDENCE TO COLLECT

- Resource inventory reconciled to discovery
- Vulnerability disclosure program and its public route
- Security staffing and budget evidence
- Supply chain risk decision records

HOW TO DOCUMENT IT

Record whether dedicated security staffing and budget exist proportionate to the service, since this is an explicit requirement and is one of the few places the indicators address organizational investment directly.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the provider has no dedicated security budget or staffing and no vulnerability disclosure program, so two explicit requirements of this indicator are unmet irrespective of the technical measures in place.

KSI-TPR Third-Party Information Resources

WHAT THE RULE REQUIRES

A secure offering understands, monitors, and manages supply chain risks from third-party information resources. Validation requires identifying all third-party information resources; regularly confirming that services handling federal information, or likely to impact its confidentiality, integrity, or availability, are FedRAMP authorized and securely configured; identifying and prioritizing mitigation of potential supply chain risks; and monitoring third-party software resources for upstream vulnerabilities, with contractual notification requirements or active monitoring services.

WHY IT EXISTS

The requirement that third-party services handling federal information be themselves FedRAMP authorized is the flow-down that keeps the assurance chain intact, and it is where providers most often discover a dependency they cannot certify. The upstream vulnerability monitoring requirement is specific about mechanism: contractual notification or active monitoring, which excludes relying on public disclosure to surface a problem.

HOW TO ASSESS IT

1. Compile third-party dependencies independently and compare against the provider's identified set.
2. Verify third parties handling federal information hold FedRAMP authorization.
3. Check upstream vulnerability monitoring operates through notification or active monitoring rather than passively.
4. Agency side: assess whether any unauthorized third party sits in the path of agency data.

EVIDENCE TO COLLECT

- Third-party resource inventory with authorization status
- Contractual notification provisions or monitoring service evidence
- Supply chain risk prioritization

HOW TO DOCUMENT IT

Record third parties handling federal information that lack FedRAMP authorization, since these break the assurance chain and are consequential for the agency regardless of the provider's own posture.

EXECUTIVE SUMMARY TREATMENT

Suggested language: federal information is processed by a stated number of third-party services that do not hold FedRAMP authorization, so part of the delivery chain carries no federal assurance at all.

KSI-CED Cybersecurity Education

WHAT THE RULE REQUIRES

A secure provider continuously educates employees on cybersecurity measures and tests them regularly to ensure their knowledge is satisfactory. Validation requires that all employees receive security awareness training, and that role-specific training is required for high risk roles, including at least roles with privileged access.

WHY IT EXISTS

This is the shortest indicator and the one most easily satisfied on paper. The distinguishing element is testing: the theme statement requires that employees be tested regularly to confirm knowledge is satisfactory, which is a higher bar than completion tracking. Role-specific training for privileged roles is named as a floor rather than a ceiling.

HOW TO ASSESS IT

1. Reconcile training completion against the full employee population.
2. Verify knowledge is tested rather than only attendance recorded.
3. Confirm privileged-access roles receive role-specific training beyond general awareness.
4. Check training recurs rather than occurring only at onboarding.

EVIDENCE TO COLLECT

- Training completion against full population
- Knowledge testing results
- Role-specific training content for privileged roles

HOW TO DOCUMENT IT

Record whether knowledge is tested or only completion tracked, since the indicator's theme statement requires testing and completion statistics measure attendance rather than knowledge.

EXECUTIVE SUMMARY TREATMENT

Suggested language: security training completion is tracked but knowledge is never tested, and privileged-access personnel receive only general awareness training, so the indicator's explicit requirements are unmet.

KSI-RPL Recovery Planning

WHAT THE RULE REQUIRES

A secure offering defines, maintains, and tests incident response and recovery capabilities to ensure minimal service disruption and data loss during incidents and contingencies. Validation requires defining Recovery Time Objectives and Recovery Point Objectives, developing and maintaining a recovery plan aligned with those objectives, performing system backups aligned with the recovery objectives, and regularly testing the capability to recover from incidents and contingencies.

WHY IT EXISTS

The alignment requirement is what gives this indicator teeth: backups must align with the stated recovery point objective, and the plan must align with both objectives, so an organization cannot state ambitious objectives while backing up on a schedule that cannot meet them. Regular testing of the capability, not the plan, is required, which distinguishes demonstrated recovery from documented intent.

HOW TO ASSESS IT

1. Verify RTO and RPO are defined and that backup frequency can actually meet the stated RPO.
2. Test whether recovery has been demonstrated within the stated RTO, rather than only planned for.
3. Check testing is regular and covers the capability rather than being a plan walkthrough.
4. Agency side: compare stated objectives against the availability requirements of the containing system.

EVIDENCE TO COLLECT

- Defined RTO and RPO
- Backup frequency against RPO
- Recovery test results with achieved times

HOW TO DOCUMENT IT

Compare demonstrated recovery times against stated objectives, and backup frequency against the stated recovery point objective, since arithmetic mismatches between them are common and conclusive.

EXECUTIVE SUMMARY TREATMENT

Suggested language: backup frequency cannot meet the stated recovery point objective, and recovery has never been tested against the stated recovery time objective, so the published objectives are unachievable and unverified.

KSI-INR Incident Reporting

WHAT THE RULE REQUIRES

A secure offering documents, reports, and analyzes security incidents to ensure regulatory compliance and continuous security improvement. Validation requires reporting incidents according to FedRAMP requirements and the provider's own policies, maintaining a log of incidents and periodically reviewing past incidents for patterns or vulnerabilities, and generating after action reports and regularly incorporating lessons learned into operations.

WHY IT EXISTS

The pattern review and lessons learned requirements are what distinguish this from a reporting obligation. Reporting satisfies the regulator; reviewing for patterns and feeding lessons back into operations is what reduces recurrence. For an agency, incident reporting from a provider is also the primary route by which it learns of events affecting its own data, which makes provider reporting timeliness directly an agency concern.

HOW TO ASSESS IT

1. Verify incidents are reported within FedRAMP timeframes and to the agencies affected.
2. Check the incident log is maintained and periodically reviewed for patterns.
3. Confirm after action reports exist and that lessons have actually changed operations.
4. Agency side: assess whether reporting arrangements would give the agency timely notice of an event affecting its data.

EVIDENCE TO COLLECT

- Incident log with reporting timestamps
- Pattern review records
- After action reports and resulting operational changes

HOW TO DOCUMENT IT

Record whether lessons learned have produced identifiable operational change, since after action reports that recommend without changing anything are the common failure of this requirement.

EXECUTIVE SUMMARY TREATMENT

Suggested language: after action reports are produced but no operational change has followed from any of them, and recurring incident patterns across the period were not identified, so the improvement loop this indicator requires is not closing.

Ongoing Certification

Five entries on what a provider must do to keep a Certification once granted. Almost entirely orange: this is where CR26 changed the most, and where legacy operational practice maps least well onto the new rules.

Three legacy artefacts were the organizing structure of Rev5 operations, and CR26 alters or removes all three. Continuous monitoring became Ongoing Certification, because the old term had collapsed into meaning vulnerability scanning while the requirements are much broader, and because failing to perform them costs the Certification. Vulnerability management broadened well past monthly scanning to detection and response for all potential weaknesses. And POA&Ms were eliminated outright, replaced by a list of Accepted Weaknesses on the reasoning that POA&Ms were mostly used to accept weaknesses for extended periods anyway.

For agency readers, the Accepted Weaknesses list is the single most informative artefact in any package. It is an explicit statement of what the provider has decided to live with. The agency must decide separately whether it can, and that decision belongs to the authorizing official rather than to the provider.

The removal of the significant change request process deserves particular attention. It was effectively an external control, and it is gone. Assurance that a service remains as assessed now rests entirely on provider change discipline and continuous validation.

Quick reference: Ongoing Certification

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [cyb](#) or [ai](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
Ongoing Certification CR26	Ongoing Certification: what replaced continuous monitoring	Ongoing Certification process documentation
VDR CR26	Vulnerability Detection and Response	Detection sources and coverage
Accepted Weaknesses CR26	Accepted Weaknesses: the replacement for POA&Ms	Accepted Weaknesses list
Change CR26	Change management and the end of significant change requests	Change management evidence
Retention	Retaining and losing Certification	CR26 adoption plan with dates

Ongoing Certification Ongoing Certification: what replaced continuous monitoring

WHAT THE RULE REQUIRES

CR26 replaced the term continuous monitoring with Ongoing Certification for provider obligations. FedRAMP's stated reason is that continuous monitoring had become synonymous with vulnerability scanning for most stakeholders, while the requirements are far broader than that, and failing to perform them results in loss of Certification. The term continuous monitoring is now generally reserved for Collaborative Continuous Monitoring with agencies, and agencies must still perform continuous monitoring under Circular A-130 in their own right.

WHY IT EXISTS

The renaming carries a warning: Ongoing Certification is a condition of retaining certification, not a reporting courtesy. Providers accustomed to treating monthly deliverables as an administrative obligation, separable from the certification itself, are working from the wrong model. CR26 also states that Ongoing Certification requirements have been adjusted substantially and require changes to methodology and approach, so carrying forward a legacy monthly process will not satisfy them.

HOW TO ASSESS IT

1. Provider side: verify the ongoing obligations are understood as conditions of retaining Certification.
2. Provider side: assess whether the methodology has been updated for CR26 or carried forward from legacy practice.
3. Agency side: confirm the agency performs its own continuous monitoring under A-130 rather than relying on the provider's.
4. Both: distinguish Ongoing Certification obligations from Collaborative Continuous Monitoring arrangements.

EVIDENCE TO COLLECT

- Ongoing Certification process documentation
- Evidence of methodology change for CR26
- Agency continuous monitoring under A-130

HOW TO DOCUMENT IT

Record whether the agency performs its own continuous monitoring or relies on the provider's Ongoing Certification, since these are different obligations serving different parties and the agency's is not discharged by the provider's.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the agency performs no continuous monitoring of its own for certified cloud services, relying instead on the provider's Ongoing Certification, so the agency's obligation under Circular A-130 is unmet.

VDR Vulnerability Detection and Response

WHAT THE RULE REQUIRES

CR26 scaled vulnerability management widely beyond traditional monthly vulnerability scanning, and requires meaningful investment in the detection and response of all potential weaknesses. The scope extends past scan findings to weaknesses identified through any route, and the emphasis is on detection capability and response rather than on the cadence of a scanning deliverable.

WHY IT EXISTS

The legacy model produced a predictable pattern: monthly scans, a large finding count, and a plan of action absorbing the backlog. Broadening the requirement to all potential weaknesses and emphasising response is aimed at that pattern directly. For assessment purposes it means scan cadence is no longer the question; detection breadth and response timeliness are.

HOW TO ASSESS IT

1. Assess detection breadth across routes beyond scanning, including code analysis, disclosure reports, and third-party notification.
2. Measure response timeliness by severity rather than counting findings.
3. Verify coverage extends across the full assessment scope rather than to scannable assets only.
4. Agency side: examine whether weaknesses affecting agency data are communicated.

EVIDENCE TO COLLECT

- Detection sources and coverage
- Response timeliness by severity
- Weakness population from all routes

HOW TO DOCUMENT IT

Record detection routes in use, since a programme resting solely on periodic scanning has not adopted the broadened requirement regardless of how diligently it scans.

EXECUTIVE SUMMARY TREATMENT

Suggested language: vulnerability management rests entirely on periodic scanning of scannable assets, with no detection through code analysis, disclosure, or supplier notification, so the broadened detection requirement is unmet.

Accepted Weaknesses Accepted Weaknesses: the replacement for POA&Ms

WHAT THE RULE REQUIRES

CR26 eliminated Plans of Action and Milestones entirely and replaced them with a list of Accepted Weaknesses. FedRAMP's stated reasoning is that POA&Ms were mostly used to accept weaknesses for an extended period anyway, so the artefact is renamed to describe what it actually was. The list records weaknesses the provider has accepted rather than remediation the provider intends.

WHY IT EXISTS

This is the change most likely to catch experienced practitioners, because the POA&M was the central artefact of legacy FedRAMP and a great deal of process was built around it. The conceptual shift is significant: a POA&M implied a commitment to remediate on a schedule, while an Accepted Weakness is an explicit statement that the provider is living with the weakness. That is more honest and it is also more exposed, because an agency reading the list sees acceptance rather than intent.

HOW TO ASSESS IT

1. Provider side: verify any remaining POA&M process has been converted rather than relabelled.
2. Agency side: read the Accepted Weaknesses list as a statement of what the provider is living with, and assess each against agency risk tolerance.
3. Both: check that weaknesses accepted are genuinely accepted decisions with an owner rather than a backlog by another name.
4. Agency side: identify accepted weaknesses that are unacceptable for the agency's specific use case.

EVIDENCE TO COLLECT

- Accepted Weaknesses list
- Acceptance decisions with owners
- Agency assessment of accepted weaknesses against its own tolerance

HOW TO DOCUMENT IT

For agencies, treat the Accepted Weaknesses list as the most informative single artefact in the package: it states what the provider has decided to live with, and the agency must decide separately whether it can.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the agency accepted a certified service into production without assessing the provider's Accepted Weaknesses against its own risk tolerance, so it has inherited a set of weaknesses the provider chose to live with and the agency has never evaluated.

Change Change management and the end of significant change requests

WHAT THE RULE REQUIRES

CR26 removed the legacy significant change request process, under which providers had to come to the government to request permission to implement changes into their commercial product. FedRAMP has described this process as having slowed provider innovation significantly. Change discipline is now governed by the provider's own change management obligations, validated through KSI-CMT and the Ongoing Certification requirements.

WHY IT EXISTS

This is a substantial transfer of trust from the government to the provider, and it removes what was effectively an external control. For providers it removes a genuine impediment. For agencies it means the service may change without any government gate, so the assurance that the service remains as assessed now rests on the provider's change discipline and on the continuous validation the model depends on.

HOW TO ASSESS IT

1. Provider side: verify change discipline is strong enough to bear the weight the removed approval gate used to carry.
2. Agency side: confirm the agency would learn of material changes to a service it depends on.
3. Both: check that continuous validation would detect a change that degraded a security outcome.
4. Provider side: examine whether legacy significant change processes have been retired or persist unnecessarily.

EVIDENCE TO COLLECT

- Change management evidence
- Agency notification arrangements for material change
- Continuous validation coverage for change detection

HOW TO DOCUMENT IT

Record whether the agency has any route to learn of material change to a certified service, since the government approval gate that previously supplied that visibility no longer exists.

EXECUTIVE SUMMARY TREATMENT

Suggested language: with the significant change request process removed, the agency has no arrangement for learning of material changes to services it depends on, so a change degrading a security outcome would not come to its attention.

Retention Retaining and losing Certification

WHAT THE RULE REQUIRES

Certification is conditional on continued compliance with the rules in force. FedRAMP has stated that cloud service providers that do not adjust to the updated rules will lose their Certification, and that failing to perform Ongoing Certification requirements results in loss of Certification. Rev5 Certifications are additionally bounded by the transition timeline, with no new Rev5 Certifications accepted after June 11, 2027 and existing ones remaining active until at least December 31, 2028.

WHY IT EXISTS

Loss of Certification is the operative consequence throughout CR26, and it is stated plainly rather than framed as a risk. For a provider, this makes CR26 adoption a continuity matter rather than a compliance improvement. For an agency, it means a service in production may lose certification during the authorization period, which is a scenario the agency should have planned for and usually has not.

HOW TO ASSESS IT

1. Provider side: verify a plan exists to meet enforcement dates, with ownership and milestones.
2. Agency side: assess what would happen if a service in production lost Certification.
3. Agency side: check whether Certification status is monitored during the authorization period rather than confirmed once at authorization.
4. Both: examine dependency concentration on services at risk of losing Certification.

EVIDENCE TO COLLECT

- CR26 adoption plan with dates
- Agency contingency for loss of Certification
- Ongoing Certification status monitoring

HOW TO DOCUMENT IT

Record whether the agency monitors Certification status through the authorization period, since status confirmed once at authorization does not reflect a certification that may lapse.

EXECUTIVE SUMMARY TREATMENT

Suggested language: Certification status is confirmed at authorization and never rechecked, so the agency would not know if a service in production lost its Certification.

CHAPTER 5

Agency Responsibilities

Five entries written from the agency side. Blue throughout, because none of these obligations changed under CR26 – which is precisely why they are worth restating. The vocabulary moved around them and they stayed put.

The first entry is the most consequential point in the guide. FedRAMP Certification does not replace the agency authorization to operate. An agency using a certified service within a federal information system must still make its own risk determination under Circular A-130. The terminology change from authorization to certification exists precisely to reinforce this, because the belief that a FedRAMP authorization was a blanket government-wide risk acceptance was among the program's most persistent problems. An agency that treats Certification as sufficient has skipped its own risk decision, and it is the agency that answers for that.

Two failures sit either side of the right position. Treating the statutory presumption of adequacy as conclusive skips the agency determination; re-performing technical assessment the Certification already covers wastes the reuse the program exists to enable. Agency effort belongs on the use case, the data, the accepted weaknesses, and the integration points – which, being nobody's default scope, are frequently monitored by neither party.

Quick reference: Agency Responsibilities

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **cyb** or **ai** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
Agency ATO Reuse	The agency authorization to operate remains separate Reuse and the presumption of adequacy	Agency ATO per certified service Agency assessment scope against certification coverage
Agency categorization	Agency categorization under FIPS 199 and 200	Agency FIPS 199 categorization
Collaborative Continuous Monitoring	Collaborative Continuous Monitoring	Agency continuous monitoring programme
Package review	Reviewing a Certification Package	Agency review records and conclusions

Agency ATO The agency authorization to operate remains separate

WHAT THE RULE REQUIRES

FedRAMP Certification does not replace the agency authorization to operate. An agency using a certified cloud service within a federal information system must still make its own risk determination and issue its own ATO under OMB Circular A-130. FedRAMP has been explicit that this has always been required and that confusion on the point was among the most persistent problems with the legacy vocabulary. Certification supplies reusable information to make that determination faster, not a substitute for making it.

WHY IT EXISTS

This is the single most important point for an agency reader, and the terminology change from authorization to certification exists precisely to reinforce it. An agency that treats certification as sufficient has skipped its own risk decision, which is both a governance failure and a FISMA compliance failure, and it will be the agency rather than the provider that answers for it.

HOW TO ASSESS IT

1. Verify an agency ATO exists for each certified service in use.
2. Check the ATO addresses the agency's specific use case and data rather than restating certification status.
3. Confirm the authorizing official saw the provider's Accepted Weaknesses and residual risk.
4. Verify the ATO is current and covers the service as currently consumed.

EVIDENCE TO COLLECT

- Agency ATO per certified service
- Risk determination reflecting agency use case
- Evidence the AO received the provider's weakness information

HOW TO DOCUMENT IT

Record whether the authorizing official had the provider's Accepted Weaknesses in front of them, since an ATO granted on certification status alone accepted risks nobody enumerated.

EXECUTIVE SUMMARY TREATMENT

Suggested language: authorizations to operate for certified cloud services were granted on the basis of Certification status alone, without the authorizing official reviewing the provider's accepted weaknesses, so the risk accepted was never actually characterised.

Reuse Reuse and the presumption of adequacy

WHAT THE RULE REQUIRES

The FedRAMP Authorization Act directs the program to support agency review, reuse, and standardization of security assessments of cloud products and services, and establishes a statutory presumption of adequacy for FedRAMP authorizations. Reuse is the mechanism by which the program's cost is amortized across government: one assessment, many agency decisions. The presumption supports reuse but does not remove the agency's own determination.

WHY IT EXISTS

Reuse is the economic rationale for the entire program, and agencies undermine it by re-performing assessment work the certification already supplies. The opposite failure is treating the presumption of adequacy as conclusive. The correct position sits between: accept the assessment, focus agency effort on the use case, the data, the accepted weaknesses, and the integration.

HOW TO ASSESS IT

1. Assess whether the agency duplicates assessment work already covered by the Certification.
2. Check agency effort concentrates on use-case-specific risk rather than re-testing provider controls.
3. Verify the presumption of adequacy is not treated as removing the agency determination.
4. Examine whether prior agency authorizations of the same service are leveraged.

EVIDENCE TO COLLECT

- Agency assessment scope against certification coverage
- Use-case-specific risk analysis
- Reuse of prior agency work

HOW TO DOCUMENT IT

Record where agency assessment duplicates certification coverage, since this is the waste the statute directs the program to eliminate and it consumes effort better spent on use-case risk.

EXECUTIVE SUMMARY TREATMENT

Suggested language: agency review re-performs technical assessment already covered by the Certification while performing no analysis of the agency's own use case, inverting where the effort should be spent.

Agency categorization Agency categorization under FIPS 199 and 200

WHAT THE RULE REQUIRES

Agencies categorize their information systems under FIPS 199 by the potential impact of a loss of confidentiality, integrity, or availability, and under FIPS 200 must set the overall impact level at the highest of the three security categorizations and employ appropriately tailored controls. A commercial cloud service is usually a component within a federal information system rather than a federal information system itself, and is not subject to laws and policies for federal information systems unless built by the government or operated on its behalf under explicit contract.

WHY IT EXISTS

This distinction is the conceptual foundation of the class system and is routinely missed. The agency categorizes its system; the provider certifies its service; the class tells the agency how much assurance the service supplies toward the agency's determination. An agency that categorizes by reference to the provider's class has inverted the relationship and has not performed the categorization FIPS 200 requires of it.

HOW TO ASSESS IT

1. Verify the agency performed its own FIPS 199 categorization for the containing system.
2. Check the high water mark rule was applied across the three objectives.
3. Confirm controls were tailored for the containing system rather than inherited wholesale from the provider.
4. Examine whether the provider's class was mistaken for the agency's impact level.

EVIDENCE TO COLLECT

- Agency FIPS 199 categorization
- Control tailoring for the containing system
- Class-to-use-case adequacy analysis

HOW TO DOCUMENT IT

Record whether the agency categorization exists independently of the provider's class, since these are different determinations made by different parties for different purposes.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the agency did not perform its own FIPS 199 categorization for systems incorporating certified cloud services, treating the provider's Certification Class as the impact level instead, so the control baseline for those systems was never determined.

Collaborative ConMon Collaborative Continuous Monitoring

WHAT THE RULE REQUIRES

Under CR26 the term continuous monitoring is generally reserved for Collaborative Continuous Monitoring between agencies and providers, distinct from the provider's Ongoing Certification obligations. Agencies retain their own continuous monitoring obligations under Circular A-130 for the federal information systems they operate, and collaboration is the mechanism by which agency and provider monitoring interact.

WHY IT EXISTS

Separating the terms clarifies who owes what. The provider's Ongoing Certification is owed to FedRAMP as a condition of Certification; the agency's continuous monitoring is owed under A-130 for its own system. Neither discharges the other, and the collaborative arrangement is what connects them. Agencies that assume provider monitoring covers their obligation have a gap that will surface at the next FISMA assessment.

HOW TO ASSESS IT

1. Verify the agency has its own continuous monitoring for systems incorporating certified services.
2. Check what collaborative arrangements exist with providers and whether they operate.
3. Confirm the agency receives the information it needs to monitor its own system.
4. Assess whether agency monitoring covers the integration points, which no provider monitors.

EVIDENCE TO COLLECT

- Agency continuous monitoring programme
- Collaborative arrangements with providers
- Integration point monitoring

HOW TO DOCUMENT IT

Record whether integration points between agency systems and certified services are monitored, since these belong to neither party's default scope and are consequently monitored by nobody.

EXECUTIVE SUMMARY TREATMENT

Suggested language: integration points between agency systems and certified cloud services are monitored by neither the agency nor the provider, leaving the connections through which agency data actually flows unobserved.

Package review Reviewing a Certification Package

WHAT THE RULE REQUIRES

An agency assessing whether to use a certified service reviews the Certification Package Overview and Security Decision Record, together with the accepted weaknesses and the independent assessor's attestation. Package materials differ substantially between the 20x and Rev5 paths: 20x packages centre on Key Security Indicator validations with automated evidence, while Rev5 packages follow the control-by-control model. FedRAMP has run agency support groups to help agencies work through the differences.

WHY IT EXISTS

A reviewer trained on Rev5 packages will not find what they expect in a 20x package, and the absence of control-by-control narrative can be mistaken for an absence of rigour. The information is present in a different form: indicator validations against the running system rather than descriptions of intended implementation. Reviewers who do not adjust will either reject adequate packages or, more likely, approve them without knowing what they read.

HOW TO ASSESS IT

1. Verify reviewers can identify which path a package came through and know what to expect from each.
2. Check reviews address the accepted weaknesses and the assessor's qualifications and scope.
3. Assess whether reviewers examine boundary definition against intended use.
4. Confirm review conclusions address the agency's use case rather than restating the package.

EVIDENCE TO COLLECT

- Agency review records and conclusions
- Reviewer training on 20x package structure
- Boundary and use case analysis

HOW TO DOCUMENT IT

Record whether reviewers have been equipped for 20x packages, since a reviewer applying Rev5 expectations to a 20x package is not performing a meaningful review in either direction.

EXECUTIVE SUMMARY TREATMENT

Suggested language: agency reviewers have received no preparation for FedRAMP 20x package materials and apply Rev5 expectations to them, so reviews of 20x packages do not establish whether the service is adequate for the intended use.

CHAPTER 6

FedRAMP Rev5: The Legacy Path

Seven entries on the legacy path: what it still requires, what CR26 changed about it, and how to plan the exit. Rev5 is not frozen while it winds down. It is being updated so that it provides security signals balanced with 20x, which means providers must absorb changes to a certification type they will eventually have to leave.

The dates are the operative facts. No new Rev5 Certifications after 11 June 2027; existing ones remain active until at least 31 December 2028 unless FedRAMP directs otherwise. For agencies, that makes Rev5 certifications in the estate a scheduled expiry, and providers without published transition plans represent assurance that will lapse on a known date. Ask for the plan.

The most significant assessment change is that FedRAMP removed most of its own organization-defined parameter values from the baselines and expects providers to set them. Assessment used to be largely conformance checking against a known number. Now the provider chooses the value and someone has to judge whether it is adequate. Record any parameter materially weaker than the value FedRAMP previously supplied, with the stated rationale, because that is where devolved judgment most directly affects assurance.

On transition: the gap between the two models is engineering capability, not documentation effort. A plan that addresses document conversion has substantially understated the work.

Quick reference: Rev5 Legacy

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [CYB](#) or [AI](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
Rev5 status CR26	Rev5 status and the transition timeline	Rev5 certification inventory with dates
Rev5 controls CR26	Rev5 control guidance and the SP 800-53 baseline	Provider-defined parameter values with rationale
Rev5 package CR26	Rev5 package materials under CR26	Package materials in current formats
Rev5 ongoing CR26	Rev5 Ongoing Certification changes	Accepted Weaknesses list replacing POA&M
Rev5 boundary	The Rev5 FedRAMP boundary	Boundary definition and diagrams
Rev5 assurance	Rev5 assurance and assessment	Assessment materials with dates and scope
Rev5 transition CR26	Planning the transition to 20x	Transition plan with milestones

Rev5 status Rev5 status and the transition timeline

WHAT THE RULE REQUIRES

FedRAMP Rev5 is retained as a legacy Certification Type. FedRAMP will stop accepting new Rev5 Certifications on June 11, 2027, and existing Rev5 Certifications remain active until at least December 31, 2028 unless FedRAMP is otherwise directed. Rev5 continues to be updated under CR26 so that it provides security signals balanced with those of 20x Certifications, which means Rev5 is not frozen: it is changing while it winds down.

WHY IT EXISTS

The combination of a closing path and continuing change is awkward for planning. A provider on Rev5 must absorb CR26 changes to a certification type it will eventually have to leave, which is why FedRAMP advises transitioning as quickly as possible. For agencies, Rev5 certifications in the estate have a known horizon, and services whose providers have no transition plan represent a scheduled loss of assurance.

HOW TO ASSESS IT

1. Provider side: confirm awareness of both dates and a transition plan with milestones.
2. Agency side: inventory Rev5-certified services in use and identify providers without transition plans.
3. Both: check that CR26 changes applicable to Rev5 are being adopted despite the wind-down.
4. Agency side: assess dependency exposure to services that may not transition.

EVIDENCE TO COLLECT

- Rev5 certification inventory with dates
- Provider transition plans
- CR26 adoption for Rev5 rule sets

HOW TO DOCUMENT IT

For agencies, record which Rev5-certified services in the estate have providers with no stated transition plan, since these represent assurance that will lapse on a known date.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of Rev5-certified services in production are supplied by providers with no published transition plan to FedRAMP 20x, so the agency faces a scheduled loss of federal assurance for those services.

Rev5 controls Rev5 control guidance and the SP 800-53 baseline

WHAT THE RULE REQUIRES

Rev5 Certification rests on the NIST SP 800-53 Rev 5 control baselines with FedRAMP guidance layered over them. Under CR26, FedRAMP removed most of its FedRAMP-defined organizational requirements within those baselines, and instead expects providers to define these themselves, with providers encouraged to compete on quality and customer experience rather than adopting the maximum value FedRAMP previously supplied.

WHY IT EXISTS

This is a substantial change to how Rev5 assessment works. Under the previous model FedRAMP supplied the organization-defined parameter values, so assessment largely checked conformance to a known number. With most of those removed, the provider sets the value and the assessor must judge whether it is adequate. An assessment that checks conformance to a provider-chosen parameter without evaluating the choice establishes very little.

HOW TO ASSESS IT

1. Identify parameters now set by the provider rather than by FedRAMP.
2. Assess whether provider-chosen values are adequate for the service and its agency use cases, not merely conformed to.
3. Agency side: check whether provider-defined parameters meet agency requirements, which may be more stringent.
4. Both: examine whether values were reduced from the previous FedRAMP-supplied maximums and on what basis.

EVIDENCE TO COLLECT

- Provider-defined parameter values with rationale
- Comparison against previous FedRAMP-supplied values
- Agency requirements for comparison

HOW TO DOCUMENT IT

Record parameters where the provider's value is materially weaker than the previously supplied FedRAMP value, together with the stated rationale, since this is where the devolution of judgment most directly affects assurance.

EXECUTIVE SUMMARY TREATMENT

Suggested language: provider-defined parameter values are materially weaker than the values FedRAMP previously specified, with no documented rationale, and the agency's own requirements are more stringent than several of them.

Rev5 package Rev5 package materials under CR26

WHAT THE RULE REQUIRES

CR26 requires large adjustments to the Certification Package itself for Rev5, including transition away from Word and Excel-based templates toward simplified JSON documents and, in some cases, optional OSCAL. Providers are expected to acquire or build modern GRC capabilities to collaborate on these materials and populate them from real-world data using automation, rather than maintaining hand-crafted documents. The renamed artefacts apply to Rev5 as well: Certification Package Overview and Security Decision Record replace the System Security Plan and appendices.

WHY IT EXISTS

The format change is where many Rev5 providers will feel CR26 most acutely, because the legacy process was built around large hand-maintained documents and the people who maintain them. Moving to generated, machine-readable materials is not a formatting exercise; it requires the underlying data to exist in a system that can produce them, which many providers do not have.

HOW TO ASSESS IT

1. Verify materials are moving to the required formats within the applicable deadlines.
2. Assess whether GRC capability exists to generate materials from data rather than transcribe them.
3. Check materials are current, since generated materials should reflect present state.
4. Agency side: confirm reviewers can consume the new formats.

EVIDENCE TO COLLECT

- Package materials in current formats
- GRC tooling capability
- Generation evidence and currency

HOW TO DOCUMENT IT

Record whether materials are generated or hand-maintained, since this determines both CR26 compliance and whether the package describes the service as it currently operates.

EXECUTIVE SUMMARY TREATMENT

Suggested language: certification materials remain hand-maintained in legacy document formats with no GRC capability to generate them from system data, so the organization is not positioned to meet the CR26 format requirements.

Rev5 ongoing Rev5 Ongoing Certification changes

WHAT THE RULE REQUIRES

CR26 applies large adjustments to Ongoing Certification requirements for Rev5, requiring changes to methodology and approach that every provider must adopt within the required timelines. The elimination of POA&Ms in favour of Accepted Weaknesses applies here, as does the broadening of vulnerability management beyond monthly scanning, and the removal of the significant change request process.

WHY IT EXISTS

These changes reach the operational core of a legacy FedRAMP programme. The monthly deliverable cycle, the POA&M, and the significant change request were the three artefacts around which Rev5 operations were organized, and CR26 alters or removes all three. A provider that treats CR26 as a documentation update will discover the changes are procedural, and that the people and tooling supporting the old cycle do not map onto the new one.

HOW TO ASSESS IT

1. Verify the POA&M process has been converted to Accepted Weaknesses in substance rather than renamed.
2. Check vulnerability management has broadened beyond the monthly scan cycle.
3. Confirm significant change request processes have been retired and replaced by internal change discipline.
4. Assess whether adoption is within the required timelines.

EVIDENCE TO COLLECT

- Accepted Weaknesses list replacing POA&M
- Broadened vulnerability detection evidence
- Change management replacing significant change requests
- Adoption timeline against deadlines

HOW TO DOCUMENT IT

Record whether the three legacy artefacts have been genuinely converted or merely relabelled, since relabelling a POA&M as an Accepted Weaknesses list without changing how weaknesses are treated misses the point of the change.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the POA&M has been relabelled as an Accepted Weaknesses list without any change to how weaknesses are triaged or accepted, so the artefact is renamed while the practice CR26 sought to change continues.

Rev5 boundary The Rev5 FedRAMP boundary

WHAT THE RULE REQUIRES

The Rev5 rule set defines its own boundary requirements, distinct from the 20x Minimum Assessment Scope though serving the same purpose: establishing what is assessed and what a Certification covers. Boundary definition governs which components, services, and third-party resources fall within the assessed scope and therefore within the assurance the Certification supplies.

WHY IT EXISTS

Boundary problems are path-independent. Whatever the certification type, a boundary drawn to exclude components that handle federal information produces a certification that does not cover the service as consumed. The Rev5 model's reliance on documentation rather than continuous validation makes boundary misstatement somewhat harder to detect, because there is no running validation that would expose an excluded component.

HOW TO ASSESS IT

1. Test the boundary against actual data flows rather than the documented architecture.
2. Identify components handling federal information that sit outside the boundary.
3. Examine management, support, and monitoring planes for boundary exclusion.
4. Agency side: compare the certified boundary against the service as actually consumed.

EVIDENCE TO COLLECT

- Boundary definition and diagrams
- Actual data flow evidence
- Component inventory against boundary

HOW TO DOCUMENT IT

Trace federal information through the delivery path independently of the documented boundary, and record any component handling it from outside, since documentation-based assessment will not surface this by itself.

EXECUTIVE SUMMARY TREATMENT

Suggested language: components handling federal information sit outside the certified boundary, so the Certification does not cover parts of the service through which agency data actually passes.

Rev5 assurance Rev5 assurance and assessment

WHAT THE RULE REQUIRES

Rev5 assurance rests on assessment by an independent assessor against the SP 800-53 control baseline, documented through the assessment materials and reviewed as part of the certification process. Rev5 requires agency sponsorship, which 20x does not, and depends on manual review of extensive documentation to validate compliance.

WHY IT EXISTS

The sponsorship requirement is what makes Rev5 slower and harder to enter, and the manual review burden is what the program identified as the problem 20x solves. For assessment purposes, the relevant consequence is that Rev5 assurance is point-in-time in a way 20x is designed not to be: it describes the service as assessed rather than as currently running, and the interval between assessments is where drift accumulates.

HOW TO ASSESS IT

1. Verify assessor independence and the scope of the assessment performed.
2. Establish the assessment date and assess drift since, since Rev5 assurance is point-in-time.
3. Agency side: check whether anything has changed materially since assessment, particularly given the removal of significant change requests.
4. Both: identify controls where the assessment relied on examination rather than testing.

EVIDENCE TO COLLECT

- Assessment materials with dates and scope
- Assessor independence evidence
- Change record since assessment

HOW TO DOCUMENT IT

Record the elapsed time since assessment and what has changed since, since Rev5 assurance describes a point in time and the removal of the significant change gate means more may have changed than previously.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the Rev5 assessment is a stated period old and the service has undergone material change since, with no government approval gate remaining, so the assurance describes a configuration that no longer exists.

Rev5 transition Planning the transition to 20x

WHAT THE RULE REQUIRES

FedRAMP advises all providers holding a Rev5 Certification to begin planning immediately to transition to 20x as quickly as possible, and directs providers to monitor the program's 20x pages for current status. Transition involves more than repackaging: the 20x model requires automated validation against the running service, machine-readable evidence, and instrumentation that the documentation-led Rev5 model does not.

WHY IT EXISTS

The gap between the two models is engineering capability rather than documentation effort, which is why the transition timeline is longer than it appears. A provider that begins by rewriting documents will discover the requirement is to instrument systems. Starting late compresses that work against a fixed date at which Rev5 certification is no longer available.

HOW TO ASSESS IT

1. Verify a transition plan exists with milestones referenced to the June 2027 and December 2028 dates.
2. Assess whether the plan addresses instrumentation and automation rather than documentation conversion.
3. Check ownership and resourcing for the transition.
4. Agency side: request provider transition plans for services the agency depends on.

EVIDENCE TO COLLECT

- Transition plan with milestones
- Automation and instrumentation workstream
- Resourcing and ownership

HOW TO DOCUMENT IT

Record whether the transition plan addresses instrumentation or only documentation, since the latter substantially underestimates the work and will not produce a 20x-capable evidence base.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the transition plan to FedRAMP 20x addresses documentation conversion only, with no workstream for the automated validation and machine-readable evidence the model requires, so the plan substantially understates the work remaining before the Rev5 window closes.

Glossary

Terms are listed alphabetically. Each is also indexed at the point of first use.

Accepted Weaknesses

The list that replaced Plans of Action and Milestones under CR26. Records weaknesses the provider has decided to live with, rather than remediation it intends. For an agency, the single most informative artefact in a package.

Advisor

A party that assists a provider in preparing for Certification. Confers no FedRAMP status, and cannot also serve as the independent assessor for the same service.

Agency ATO

An agency's authorization to operate, issued under OMB Circular A-130. Separate from and not replaced by FedRAMP Certification. The agency must make its own risk determination.

Certification Class

The A/B/C/D structure that replaced Low, Moderate, and High impact levels under CR26. Describes the assurance a service supplies, not the categorization of the agency system it sits within. Deliberately does not map one-to-one onto impact levels.

Certification Package Overview

With the Security Decision Record, the artefact that replaced the System Security Plan and its appendices.

Collaborative Continuous Monitoring

Monitoring collaboration between an agency and a provider. Under CR26 the term 'continuous monitoring' is generally reserved for this and for the agency's own A-130 obligation, distinct from the provider's Ongoing Certification.

CR26

The FedRAMP Consolidated Rules for 2026. Effective 4 July 2026, enforceable 1 January 2027. The first milestone of an annually updated rule set rather than a one-time change.

FedRAMP 20x

The modernized certification path. Uses Key Security Indicators, requires no agency sponsor, and relies on automated validation against the running service.

FedRAMP Certification

The label the program grants to a cloud service offering meeting its requirements. Replaced 'FedRAMP authorization' under CR26. Not a government-wide risk acceptance and not a substitute for an agency ATO.

FedRAMP Rev5

The legacy certification path, based on NIST SP 800-53 Rev 5 baselines and requiring agency sponsorship. Closes to new certifications 11 June 2027; existing certifications active until at least 31 December 2028.

Information resource

The unit to which Key Security Indicators apply: assets, software, services, and in some indicators personnel, within the assessment scope.

Just-in-time privilege

Granting privileged access for a bounded period rather than holding it standing. Required by KSI-IAM.

Key Security Indicator

A measurable security capability that replaces control-by-control narrative under 20x. Each carries validation requirements that must be met and reported as true. Abbreviated KSI.

Marketplace

The public register of cloud service offerings and their FedRAMP status. Updated for the class structure under CR26; distinguishes 20x and Rev5 by filter rather than by separate label.

Minimum Assessment Scope

The set of information resources to which all Key Security Indicators must be applied. The 20x boundary concept.

Ongoing Certification

The provider obligations that replaced 'continuous monitoring' terminology under CR26. Broader than vulnerability scanning, and a condition of retaining Certification rather than a reporting courtesy.

OSCAL

Open Security Controls Assessment Language. A machine-readable format, optional for some CR26 package materials.

Phishing-resistant MFA

Multi-factor authentication using methods difficult to intercept or impersonate. Required by KSI-IAM. Code-based one-time passwords do not satisfy it.

POA&M

Plan of Action and Milestones. Eliminated entirely under CR26 and replaced by Accepted Weaknesses, on the reasoning that POA&Ms were mostly used to accept weaknesses for extended periods anyway.

Presumption of adequacy

The statutory presumption supporting agency reuse of FedRAMP assessments. Supports reuse; does not remove the agency's own authorization decision.

Security Decision Record

With the Certification Package Overview, the artefact replacing the System Security Plan. Records the security decisions a provider actually made, rather than plans for an agency to implement.

Significant change request

The legacy process requiring providers to seek government permission before changing their commercial product. Removed under CR26; provider change discipline now carries the weight it used to.

Third-party information resource

An external service or component within the assessment scope. Under KSI-TPR, those handling federal information must themselves be FedRAMP authorized.

Workpaper

The assessor's record of what was tested, how, what was found, and what was concluded. Written so a

reviewer can follow the reasoning without re-performing the work.

Index of Terms and Concepts

- Accepted Weaknesses, [47](#)
- Accepted Weaknesses: the replacement for POA&Ms, [30](#)
- Advisor, [47](#)
- Agency ATO, [47](#)
- Agency categorization under FIPS 199 and 200, [36](#)
- Assurance and the independent assessor, [13](#)
- Automated validation and machine-readable evidence, [15](#)
- Certification Class, [47](#)
- Certification Classes A, B, C, and D, [3](#)
- Certification Package Overview, [47](#)
- Change Management, [21](#)
- Change management and the end of significant change requests, [31](#)
- Choosing a path: FedRAMP 20x or FedRAMP Rev5, [5](#)
- Cloud Native Architecture, [17](#)
- Collaborative Continuous Monitoring, [37](#), [47](#)
- CR26, [47](#)
- Cybersecurity Education, [24](#)
- FedRAMP 20x, [47](#)
- FedRAMP Certification, [47](#)
- FedRAMP Certification: what it is and what it is not, [2](#)
- FedRAMP Rev5, [47](#)
- How classes align with agency use cases, [4](#)
- Identity and Access Management, [19](#)
- Incident Reporting, [26](#)
- Information resource, [48](#)
- Just-in-time privilege, [48](#)
- Key Security Indicator, [48](#)
- Marketplace, [48](#)
- Marketplace listing under 20x, [10](#)
- Minimum Assessment Scope, [48](#)
- Monitoring, Logging, and Auditing, [20](#)
- Obtaining 20x Certification, [11](#)
- Ongoing Certification, [48](#)
- Ongoing Certification: what replaced continuous monitoring, [28](#)
- OSCAL, [48](#)
- Package materials: Certification Package Overview and Security Decision Record, [14](#)
- Phishing-resistant MFA, [48](#)
- Planning the transition to 20x, [46](#)
- POA&M, [48](#)
- Policy and Inventory, [22](#)
- Presumption of adequacy, [48](#)
- Recovery Planning, [25](#)
- Retaining and losing Certification, [32](#)
- Reuse and the presumption of adequacy, [35](#)
- Rev5 assurance and assessment, [45](#)
- Rev5 control guidance and the SP 800-53 baseline, [41](#)
- Rev5 Ongoing Certification changes, [43](#)
- Rev5 package materials under CR26, [42](#)
- Rev5 status and the transition timeline, [40](#)
- Reviewing a Certification Package, [38](#)
- Roles: FedRAMP, agencies, providers, assessors, advisors, [6](#)
- Security Decision Record, [48](#)
- Service Configuration, [18](#)
- Significant change request, [48](#)
- The 20x FedRAMP boundary and Minimum Assessment Scope, [12](#)
- The agency authorization to operate remains separate, [34](#)
- The CR26 adoption timeline, [8](#)
- The FedRAMP Marketplace and listing, [7](#)
- The Rev5 FedRAMP boundary, [44](#)
- Third-party information resource, [48](#)
- Third-Party Information Resources, [23](#)
- Vulnerability Detection and Response, [29](#)
- Workpaper, [48](#)